

Plan de Respuesta a Incidente de Ransomware sobre TechCo

Jon Arana

Documento basado en las funciones del NIST Cybersecurity Framework

Identificación · Protección · Detección · Respuesta · Recuperación · Mejora continua

Índice del documento

- Fase 1. Identificación y reconocimiento del incidente
 - 1. Análisis inicial del entorno TechCo
 - 2. Identificación de activos críticos y vulnerabilidades
 - 3. Recolección de evidencias
- Fase 2. Protección y preparación
 - 4. Controles preventivos
 - 5. Protección de backups y segmentación
- Fase 3. Detección y análisis
 - 6. Indicadores de compromiso y alerta temprana
 - 7. Herramientas de monitorización
- Fase 4. Respuesta, contención y erradicación
 - 8. Activación del plan de respuesta
 - 9. Contención
 - 10. Investigación y erradicación
- Fase 5. Recuperación y continuidad
 - 11. Restauración segura
 - 12. Continuidad del negocio
- Fase 6. Mejora continua
 - 13. Lecciones aprendidas y plan de acción
- Conclusión

Fase 1. Identificación y reconocimiento del incidente

1. Análisis inicial del entorno TechCo

El documento parte de un escenario ficticio en el que TechCo, empresa dedicada a servicios en la nube y gestión de datos confidenciales, ha sufrido un ataque de ransomware iniciado mediante un correo de phishing. El objetivo de esta fase es obtener una visión inicial del incidente, identificar los sistemas afectados y preservar la información necesaria antes de realizar cambios sobre la infraestructura.

A diferencia de un análisis realizado directamente sobre los servidores de producción, las salidas de comandos incluidas en este documento se presentan como evidencia de documento simulada. No representan una ejecución real sobre la infraestructura de TechCo; sirven para mostrar cómo se documentaría una investigación siguiendo un enfoque de respuesta a incidentes.

Estado inicial del incidente

Vector inicial: correo de phishing con un archivo adjunto que aparentaba ser una factura.

Sistemas afectados: servidor de archivos, base de datos de clientes y sistemas internos de backup.

Impacto: cifrado de información y pérdida de disponibilidad de servicios críticos.

Condición crítica: los backups conectados a la misma red también fueron cifrados.

```
TechCo Incident Response Lab

$ hostname && uptime
techco-fileserver    up 2 days, 03:14, 4 users, load average: 0.92, 0.8
$ df -h
/dev/sda2  120G   108G   6.1G   95%   /
$ systemctl --failed
1 failed unit: backup-agent.service
```

Figura 1. Evidencia ilustrativa del estado inicial del servidor afectado.

2. Identificación de activos críticos y vulnerabilidades

El análisis debe comenzar por determinar qué activos son esenciales para la operación y qué impacto tendría su indisponibilidad. En TechCo se consideran críticos los sistemas que soportan los servicios al cliente, almacenan información sensible o permiten la recuperación de la infraestructura.

Activo	Criticidad	Impacto	Vulnerabilidad observada
Servidor de archivos	Alta	Pérdida de documentos y operaciones	Acceso desde red sin segmentación suficiente
Base de datos de clientes	Crítica	Pérdida/confidencialidad de datos	Exposición a movimiento lateral
Backups internos	Crítica	Imposibilidad de recuperación	Conectados a la red comprometida
Endpoints	Alta	Punto de entrada y propagación	Phishing y controles insuficientes
Identidad/AD	Crítica	Compromiso de privilegios	Necesidad de MFA y mínimo privilegio

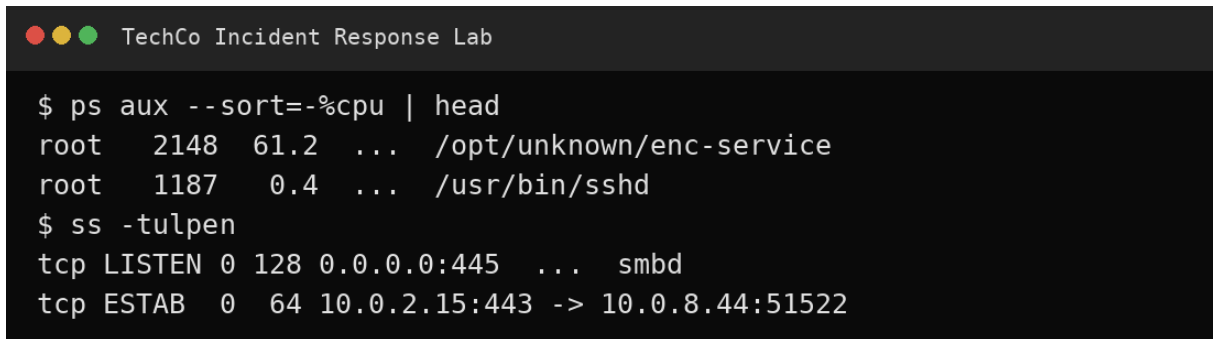
Red corporativa	Crítica	Movimiento lateral	Segmentación insuficiente
-----------------	---------	--------------------	---------------------------

3. Recolección de evidencias

Antes de eliminar archivos o restaurar equipos, el equipo de respuesta debe documentar el estado del incidente. En un documento Linux, una primera revisión puede incluir procesos, conexiones, usuarios, tareas programadas y registros.

Comandos de referencia: `ps aux --sort=-%cpu ss -tulpen who -a last -a journalctl -xe crontab -l`

Estos comandos deben utilizarse como apoyo a la investigación y no sustituyen una adquisición forense completa. En un entorno real, las evidencias deben preservarse de forma que mantengan su integridad y trazabilidad.



```

TechCo Incident Response Lab

$ ps aux --sort=-%cpu | head
root    2148  61.2  ...  /opt/unknown/enc-service
root    1187   0.4  ...  /usr/bin/sshd
$ ss -tulpen
tcp LISTEN 0 128 0.0.0.0:445  ...  smbd
tcp ESTAB  0  64 10.0.2.15:443 -> 10.0.8.44:51522

```

Figura 2. Evidencia ilustrativa de procesos y conexiones durante el análisis.

Fase 2. Protección y preparación

4. Controles preventivos

La función de Protección busca reducir la probabilidad de compromiso y limitar el impacto de una intrusión. En el escenario de TechCo, varias medidas habrían podido impedir la entrada del malware o dificultar su propagación.

Protección del correo electrónico: Implementar filtros antiphishing y antimalware, análisis de adjuntos, sandboxing y controles SPF, DKIM y DMARC.

Concienciación: Realizar formación periódica y simulaciones de phishing para enseñar a los empleados a identificar y reportar mensajes sospechosos.

Mínimo privilegio: Limitar los permisos de usuarios y separar cuentas administrativas de las cuentas utilizadas para tareas diarias.

MFA: Proteger especialmente accesos administrativos, VPN, correo y sistemas de gestión.

Gestión de parches: Mantener sistemas operativos, aplicaciones y dispositivos de red actualizados y priorizar vulnerabilidades críticas.

Hardening: Deshabilitar servicios innecesarios, restringir puertos y aplicar configuraciones seguras.

5. Protección de backups y segmentación

El fallo más grave del escenario es que los sistemas de backup permanecían dentro de la misma red comprometida. La recuperación debe diseñarse como una capacidad independiente del entorno de producción.

- Aplicar una estrategia 3-2-1 para las copias de seguridad.
- Mantener al menos una copia offline o lógicamente aislada.
- Utilizar credenciales independientes para la infraestructura de backup.
- Proteger las copias frente a eliminación o modificación no autorizada.
- Realizar pruebas periódicas de restauración.
- Segmentar servidores, usuarios, bases de datos, administración y backups.
- Restringir las comunicaciones entre segmentos mediante firewalls y reglas de mínimo privilegio.

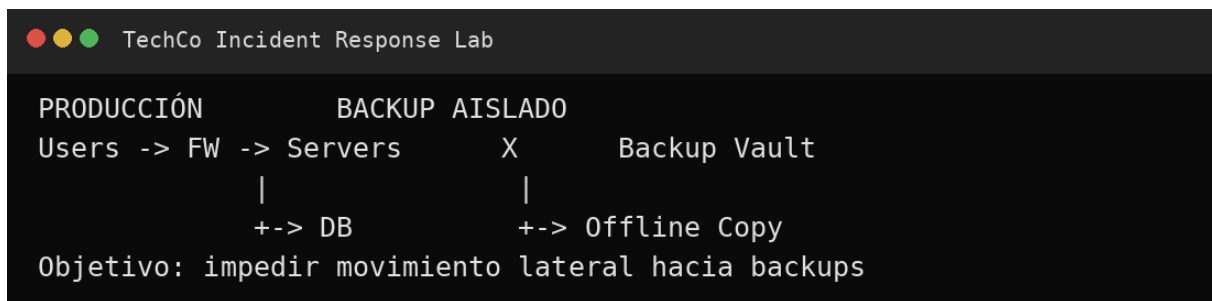


Figura 3. Evidencia conceptual de la segmentación y aislamiento de backups.

Fase 3. Detección y análisis

6. Indicadores de compromiso y alerta temprana

La ausencia de monitorización en tiempo real permitió que el ransomware se propagara antes de ser identificado. TechCo debe definir indicadores que generen alertas tempranas y establecer un procedimiento de escalado.

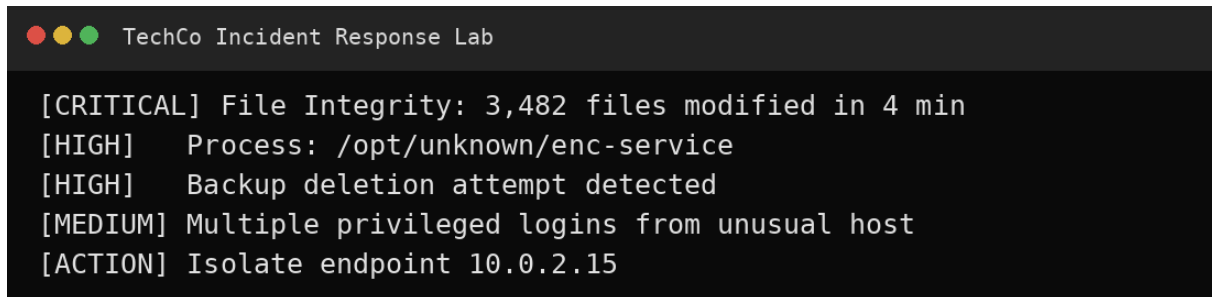
- Cifrado masivo de archivos o cambios de extensión en numerosos documentos.
- Procesos desconocidos ejecutándose desde directorios temporales o rutas no habituales.
- Desactivación de antivirus, EDR o servicios de seguridad.
- Uso anómalo de cuentas privilegiadas.
- Accesos simultáneos a numerosos servidores.
- Eliminación o modificación de backups y snapshots.
- Incremento anómalo del tráfico de red.
- Conexiones salientes hacia destinos no autorizados.
- Múltiples fallos de autenticación seguidos de un acceso exitoso.

7. Herramientas de monitorización

Una arquitectura de detección adecuada puede combinar EDR/XDR para endpoints, SIEM para correlación de eventos, IDS/IPS para la red y herramientas de monitorización de integridad de archivos. En el documento se puede representar la centralización de eventos mediante Wazuh o una plataforma equivalente.

Ejemplo de consulta de investigación: `grep -Ei`

`'encrypt|ransom|suspicious|failed|privilege' /var/log/auth.log`



```
TechCo Incident Response Lab

[CRITICAL] File Integrity: 3,482 files modified in 4 min
[HIGH]     Process: /opt/unknown/enc-service
[HIGH]     Backup deletion attempt detected
[MEDIUM]  Multiple privileged logins from unusual host
[ACTION]   Isolate endpoint 10.0.2.15
```

Figura 4. Evidencia ilustrativa de alertas tempranas de seguridad.

Fase 4. Respuesta, contención y erradicación

8. Activación del plan de respuesta

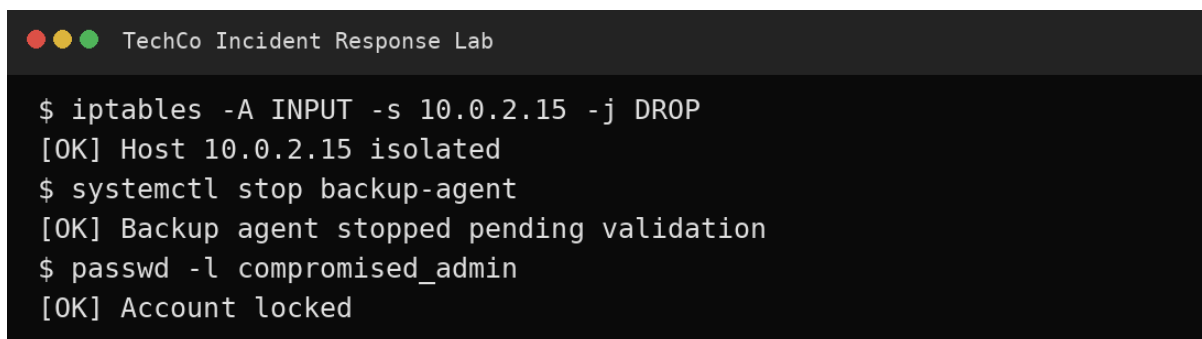
Una vez confirmado el ransomware, el responsable del incidente debe activar formalmente el plan y establecer un canal seguro de coordinación. Las decisiones deben quedar registradas en una línea temporal.

- Confirmar y clasificar el incidente como crítico.
- Designar al Incident Commander.
- Registrar hora de detección, sistemas afectados y acciones realizadas.
- Notificar a Seguridad, TI, Dirección y Legal/Compliance.
- Preservar evidencias antes de realizar acciones destructivas.
- Establecer comunicación interna controlada.

9. Contención

El objetivo inmediato es detener la propagación. Restaurar sistemas antes de contener completamente al atacante puede provocar una reinfección.

- Aislar equipos afectados de la red.
- Bloquear cuentas comprometidas y revocar sesiones sospechosas.
- Restringir temporalmente comunicaciones entre segmentos.
- Proteger y desconectar lógicamente los backups que aún estén disponibles.
- Bloquear indicadores de compromiso en EDR, firewall y proxy.
- Priorizar la protección de sistemas críticos y de identidad.



```
TechCo Incident Response Lab

$ iptables -A INPUT -s 10.0.2.15 -j DROP
[OK] Host 10.0.2.15 isolated
$ systemctl stop backup-agent
[OK] Backup agent stopped pending validation
$ passwd -l compromised_admin
[OK] Account locked
```

Figura 5. Evidencia ilustrativa de acciones de contención.

10. Investigación y erradicación

Después de contener el incidente, el equipo debe determinar el vector de entrada, alcance, movimiento lateral, posible exfiltración y mecanismos de persistencia. Posteriormente debe eliminar el malware y reconstruir los sistemas desde fuentes confiables.

- Identificar el endpoint inicialmente comprometido.
- Revisar autenticaciones y privilegios utilizados.
- Buscar persistencia en tareas programadas, servicios y mecanismos de inicio.
- Revisar conexiones salientes y posibles destinos de exfiltración.
- Restablecer credenciales comprometidas.
- Aplicar parches y corregir la causa raíz.
- Verificar que no existan mecanismos de persistencia antes de la recuperación.

Organización de la respuesta

Roles y responsabilidades

Rol	Responsabilidad principal	Momento de intervención
Incident Commander	Coordinar decisiones, prioridades y escalado	Todo el incidente
SOC/Seguridad	Detectar, investigar, contener y analizar evidencias	Detección–erradicación
TI/Sistemas	Aislar, reconstruir y restaurar infraestructura	Contención–recuperación
Backup/DR	Validar copias y ejecutar restauración	Recuperación
Legal/Compliance	Evaluar obligaciones y notificaciones	Respuesta–recuperación
Dirección	Aprobar decisiones de impacto empresarial	Todo el incidente
Comunicación/PR	Gestionar mensajes externos	Cuando corresponda

Comunicación interna y externa

La comunicación debe estar centralizada para evitar mensajes contradictorios. Internamente se debe informar a los empleados sobre los sistemas que deben evitar y los canales de reporte. Externamente, las comunicaciones a clientes, proveedores, aseguradoras o autoridades deben coordinarse con Legal/Compliance y Dirección.

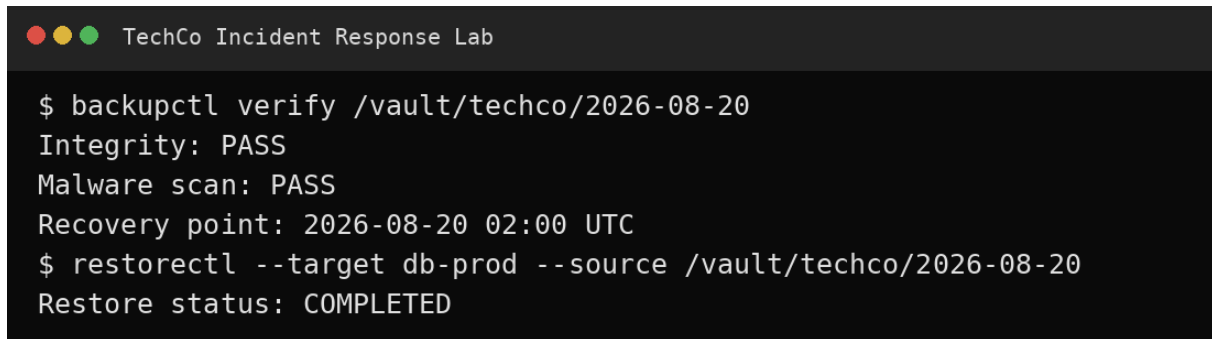
La decisión de pagar un rescate no debe tomarse de forma improvisada. Debe evaluarse con Dirección, Legal/Compliance, Seguridad y asesores especializados, teniendo en cuenta que el pago no garantiza la recuperación ni evita una posible exposición de información.

Fase 5. Recuperación y continuidad

11. Restauración segura

La recuperación comienza únicamente después de contener y erradicar el compromiso. Las copias disponibles deben validarse antes de utilizarlas y la restauración debe realizarse en un entorno limpio.

- Identificar la última copia confiable.
- Comprobar integridad y fecha de los backups.
- Asegurar un entorno de restauración limpio.
- Reconstruir primero identidad y servicios esenciales.
- Restaurar bases de datos y aplicaciones críticas.
- Realizar pruebas funcionales y de seguridad.
- Reincorporar progresivamente los sistemas a producción.
- Mantener monitorización reforzada durante la recuperación.



```
TechCo Incident Response Lab

$ backupctl verify /vault/techco/2026-08-20
Integrity: PASS
Malware scan: PASS
Recovery point: 2026-08-20 02:00 UTC
$ restorectl --target db-prod --source /vault/techco/2026-08-20
Restore status: COMPLETED
```

Figura 6. Evidencia ilustrativa de validación y restauración de un backup confiable.

12. Continuidad del negocio

Mientras los servicios principales se recuperan, TechCo debe operar mediante procedimientos de contingencia. La continuidad debe basarse en objetivos RTO y RPO previamente definidos.

Servicio	Prioridad	RTO orientativo	RPO orientativo
Servicios de clientes	Crítica	4 h	1 h
Base de datos	Crítica	4 h	1 h
Archivos internos	Alta	12 h	4 h
Sistemas secundarios	Media	24 h	8 h

Los valores de la tabla son ejemplos para el documento. En un entorno real, los RTO/RPO deben determinarse mediante un análisis de impacto al negocio y acuerdos con las áreas responsables.

Fase 6. Mejora continua

13. Lecciones aprendidas y plan de acción

Una vez recuperados los servicios, TechCo debe realizar una revisión posterior al incidente. El propósito no es solamente documentar lo ocurrido, sino convertir las causas y fallos identificados en acciones verificables.

- Construir una cronología desde el phishing hasta la contención.
- Determinar la causa raíz y los controles que fallaron.
- Medir el tiempo de detección, contención y recuperación.
- Determinar si existió exfiltración de datos.
- Evaluar la eficacia de los backups.
- Actualizar procedimientos, configuraciones y formación.
- Asignar responsables y fechas de cierre para cada acción correctiva.
- Repetir pruebas de restauración y ejercicios de ransomware.

Métricas de eficacia

Métrica	Objetivo	Cómo verificar
MTTD	Reducir tiempo de detección	Revisar timestamps SIEM/EDR
MTTC	Reducir tiempo de contención	Comparar detección vs aislamiento
MTTR	Reducir tiempo de recuperación	Comparar inicio vs servicio restaurado
Éxito de restauración	100% de pruebas críticas	Ejercicios periódicos
Cobertura MFA	100% de cuentas críticas	Auditoría de identidad
Cobertura EDR	100% de endpoints críticos	Inventario vs consola EDR

Plan de acción prioritario

- Aislar y proteger los backups.
- Implementar segmentación de red.
- Desplegar EDR/XDR y SIEM.
- Aplicar MFA a cuentas y accesos críticos.
- Fortalecer protección del correo y formación anti-phishing.
- Establecer un procedimiento formal de respuesta a incidentes.
- Definir y probar RTO/RPO.
- Realizar ejercicios de mesa y simulaciones de ransomware.
- Auditar periódicamente privilegios, servicios, puertos y configuraciones.

Conclusión

El documento de TechCo demuestra cómo una organización puede estructurar una respuesta formal ante ransomware siguiendo las funciones de Identificación, Protección, Detección, Respuesta y Recuperación del enfoque NIST.

El escenario muestra que el impacto no se debe únicamente al cifrado de los archivos. La falta de segmentación, la ausencia de detección temprana y, especialmente, la exposición de los backups a la misma red comprometida convierten un incidente inicial en una interrupción de mayor alcance.

La respuesta debe comenzar con la identificación y preservación de evidencias, continuar con la contención y erradicación, y finalizar con una recuperación segura desde fuentes confiables. La continuidad del negocio debe mantenerse mediante procedimientos alternativos y objetivos RTO/RPO previamente definidos.

Finalmente, el plan debe considerarse un documento vivo. Las lecciones aprendidas, los ejercicios de simulación y las pruebas de restauración deben utilizarse para mejorar los controles y aumentar la capacidad de TechCo para detectar, contener y recuperarse de futuros ataques.

Nota sobre las evidencias del documento

Las figuras de terminal incluidas en este documento son representaciones simuladas elaboradas para el documento. Se utilizan para mostrar el tipo de evidencia que debería recopilarse durante una investigación real y no deben interpretarse como capturas obtenidas de sistemas reales de TechCo.

Resumen de correspondencia con NIST

Función	Aplicación en TechCo	Resultado esperado
Identificar	Inventario de activos, riesgos, datos y vulnerabilidades	Conocer qué proteger y priorizar
Proteger	MFA, segmentación, backups aislados, hardening y formación	Reducir probabilidad e impacto
Detectar	EDR/XDR, SIEM, IDS/IPS y alertas de comportamiento	Reducir tiempo de detección
Responder	Activación, contención, investigación, erradicación y comunicación	Limitar propagación y daños
Recuperar	Restauración validada, continuidad y pruebas	Volver a operar de forma segura
Mejora continua	Lecciones aprendidas, métricas y ejercicios	Aumentar resiliencia futura